

TEKNİK DELİL RAPORU

Sapphire B2B Platformuna Yönelik Süregelen Siber Saldırı

Rapor No	SAP-CYBER-2026-0428-v8
Saldırı Tarihi	28 Nisan 2026 12:17 UTC — 29 Nisan 2026 10:47 UTC+ (devam ediyor)
Toplam Süre	22+ saat (iki gün boyunca)
Hedef	sapphiresc.com — Sapphire B2B Platform
İlişkilendirilen IP #1	84.44.79.182 — Bursa, TR (Vodafone sabit hat)
İlişkilendirilen IP #2	131.222.238.224 — İstanbul, TR (4GNET mobil)
İlişkilendirilen IP #3	2.57.122.173 — Romanya (UNMANAGED LTD)
İlişkilendirilen IP #4-6	172.86.70.20 / 2a0b:f4c2::6 / 2a0b:f4c2:1::1 — Tor exit
Parmak İzi	curl/8.12.1 (tüm IP'lerde aynı)
Altyapı Bağlantısı	84.44.79.182 üzerinde aitools.ait.com.tr servis ediliyor
Sahte Hesap Sayısı	42+
Saldırı Vektörü Sayısı	11 farklı vektör
Toplam Saldırı Olayı	SSRF 73+, admin denemesi 25+, RCE teşebbüsü 3+
Delil Dosyası	evidence/ — 92 dosya, 9 klasör, SHA-256 hashli
Ekran Görüntüsü	20 adet (Cloudflare Dashboard, canlı)

1. OLAY ÖZETİ

28-29 Nisan 2026 tarihlerinde sapphiresc.com platformuna hedefli, sistematik ve süregelen bir siber saldırı gerçekleştirilmektedir. Saldırgan sahte hesaplar açarak platforma giriş yapmış, ardından SSRF, port tarama, credit manipölasyonu, XSS, phishing ve Redis üzerinden uzaktan komut çalıştırma (RCE) denemeleri gerçekleştirmiştir. Saldırı iki gün boyunca, 6 farklı IP adresinden (ofis hattı, mobil internet, Romanya, Tor) devam etmiştir.

Saldırıyla ilişkilendirilen ana IP adresi (84.44.79.182) üzerinde, A.I.T. Bilgisayar Sistemleri'ne ait aitools.ait.com.tr içeriğinin servis edildiği tespit edilmiştir. A.I.T., saldırıya uğrayan platformun doğrudan rakibidir (MiraB2B ürünü).

2. KRONOLOJİK OLAY AKIŞI

Tüm olaylar UTC saatiyle (Türkiye = UTC + 3 saat) listelenmiştir.

2.1 GÜN 1 — 28 Nisan 2026

Saat (UTC)	Olay	Delil
12:17:10	Sahte hesap: 'PenTest User' pentester1777378590@deltajohnsons.com	DB User (D005)
12:18:46	Credit manipölasyonu başladı: -1000 deneme → +100 → +5.000 → +10.000 enjeksiyonu	DB Credit (D007)
12:32:43	Admin paneline yetkisiz erişim (25+ endpoint): /api/admin/stats, recent-users, fix-payment	Railway log (D002)
12:45:55	Path traversal: ../../etc/passwd.png	Railway log (D003)
13:01:13	SSRF başlangıcı — AWS IMDS: 169.254.169.254/latest/meta-data/hostname	Railway log (D003)
13:09:58	ECS container credential çalma: 169.254.170.2/v2/credentials/	Railway log (D003)
13:20:13	Webhook.site token oluşturuldu — 84.44.79.182 IP'sinden Token: e9da1ee6-ded1-4e10-8dc5-0d5ad73352a3	Webhook.site API (D009)
13:20:27	İlk SSRF callback: sunucu (162.220.234.129) webhook.site'a istek yaptı → SSRF teyidi	Webhook.site (D010)
13:40:36	Port tarama: 1 sn'de 8+ port 5432, 6379, 27017, 9200, 8443, 9090...	Railway log (D003)
15:09:23	'SSRF Proof' SVG yüklendi: iç servis listesi	CDN + DB (D024)
15:10:16	'SSRF Data Exfil Proof' SVG: kullanıcı veri dökümü (JSON)	CDN + DB (D025)
15:15:25	admin scope API key oluşturuldu: 'admin-key' — kalıcı erişim girişi	DB ApiKey (D008)
20:39:48	İkinci webhook token — yeni IP: 131.222.238.224 (İstanbul, 4GNET mobil)	Webhook.site API
20:56—21:30	XInclude dosya okuma: file:///etc/hostname file:///app/src/app/api/export/route.ts	CDN SVG

2.2 GÜN 2 — 29 Nisan 2026

Saat (UTC)	Olay	Delil
00:08—00:39	Toplu hesap oluşturma: 'NewPenTest2', 8x 'PT', 9x 'check', exfil_100000—100008 (otomatik)	DB User
08:06—08:52	Yeni hesaplar: 'Test User', 'Test User3-4', 'Farm', 'ssrf-test'	DB User
08:13:51	SSRF devam: 127.0.0.1:3000 port tarama	Railway log
08:24—08:42	Admin paneline 6x yetkisiz erişim	Railway log
08:31:10	Sapphire domain'ile sahte hesaplar: admin@, info@, support@, test@sapphireesc.com	DB User
08:33:37	'Internal Data Exfil' SVG yüklendi	CDN SVG
08:44:41	Stored XSS: <script>alert('XSS on ' + document.domain)</script>	CDN SVG
08:46:09	Docker daemon tarama: 127.0.0.1:2375, :2376, :4243	Railway log
08:52:46	Phishing SVG: sahte login formu → evil.example.com/steal	CDN SVG
09:52—09:57	84.44.79.182 Cloudflare'da görünüyor: /api/export, /api/vectorize (Tor'a geçmeden 25 dk önce)	Cloudflare Analytics (SS-010, SS-015)
10:22:36	Tor'a geçiş — 172.86.70.20 curl/8.12.1 devam ediyor	SecurityLog DB
10:22—10:27	Redis Gopher SSRF → RCE teşebbüsü: gopher://127.0.0.1:6379 → Lua io.popen() find /app, ls /tmp, /etc/passwd okuma	SecurityLog DB paste.rs payload
10:34—10:47	Tor exit değiştirerek devam: 2a0b:f4c2:1::1 (DE) üzerinden paste.rs SSRF + SVG base64 XSS denemeleri	SecurityLog DB (SS-008, SS-009)
10:47+	Güvenlik önlemleri aktif: tüm SSRF, XSS, RCE ENGELLENDİ	SecurityLog DB Railway log

Not: SS-001 — SS-020 referansları, evidence/09-screenshots/ klasöründeki Cloudflare Dashboard ekran görüntülerini ifade etmektedir. Bu görüntüler 29 Nisan 2026, 12:23-14:00 UTC+3 saatleri arasında platform sahibi Ali İlçel tarafından canlı olarak alınmıştır.

3. İLİŞKİLENDİRİLEN IP ADRESLERİ VE ALTYAPI BAĞLANTISI

3.1 Tespit Edilen IP Adresleri

IP Adresi	Konum	ISP / Tür	Tespit Yöntemi	curl
84.44.79.182	Bursa, TR	Vodafone (sabit hat)	Webhook.site token Cloudflare Analytics	Evet
131.222.238.224	İstanbul, TR	4GNET (mobil)	Webhook.site token #2	Evet
2.57.122.173	Romanya	UNMANAGED LTD ASN 47890	Cloudflare Analytics (SS-016)	Hayır*
172.86.70.20	Tor exit	Tor anonim ağ	SecurityLog DB	Evet
2a0b:f4c2::6 2a0b:f4c2:1::1	Tor exit (IPv6)	Stiftung Erneuerb. Freiheit, ASN 60729	SecurityLog DB Cloudflare (SS-015)	Evet
2001:67c:89c:...	Tor exit (IPv6)	Tor anonim ağ	SecurityLog DB	Evet

* Romanya IP'si OnePlus Android cihaz user-agent'ı ile gelmiş olup, .env ve config dosyalarına erişim denemiştir. Diğer tüm IP'lerde curl/8.12.1 parmak izi ortaktır.

6 farklı IP'de aynı araç (curl/8.12.1), aynı e-posta domain'i (deltajohnsons.com) ve aynı saldırı paterni kullanılmıştır. Bu, tüm aktivitenin aynı kişi veya ekip tarafından gerçekleştirildiğine kuvvetle işaret etmektedir.

3.2 Ana IP'nin (84.44.79.182) A.I.T. Altyapısıyla İlişkisi

Bu IP'de çalışan web servisleri incelenmiştir:

Bulgu	Değer	Doğrulama
Port 5000 — HTML	og:url = "https://aitools.ait.com.tr" og:site_name = "AIT AI-Tools" title = "AI Pattern Generator"	curl 84.44.79.182:5000 (D019)
Port 5001 — Login	AIT logolu 'Archivist' admin paneli	curl 84.44.79.182:5001 (D020, D021)
aitools.ait.com.tr	ait.com.tr'nin alt alan adı	dig aitools.ait.com.tr
ait.com.tr WHOIS	A.I.T. BİLGİSAYAR SİSTEMLERİ MAKİNE SAN. VE TİC. LTD. ŞTİ.	whois ait.com.tr (D012)
Shodan.io	Port 80, 5000 açık (27 Nisan)	shodan.io/host/... (D023)
Cloudflare	AS15924 Vodafone Net, TR	Cloudflare dashboard (SS-015)

3.3 Tor Arkasındaki Gerçek IP Tespiti

Saldırgan 29 Nisan 10:22 UTC'de Tor'a geçmiştir. Ancak aynı gün 09:52-09:57 UTC'de (Tor'a geçmeden 25 dakika önce) Cloudflare Security Analytics'te 84.44.79.182 IP'sinden sapphiresc.com'a erişim kaydedilmiştir (SS-010, SS-015). Her iki oturumda da:

- Aynı araç: curl/8.12.1
- Aynı e-posta domain'i: deltajohnsons.com
- Aynı saldırı vektörleri: SSRF, export API istismarı
- 25 dakikalık geçiş süresi: normal IP'den Tor'a

Kesin abone tespiti için BTK'dan 84.44.79.182 IP'sinin 28-29 Nisan tarihli Vodafone abone bilgilerinin istenmesi gerekmektedir.

4. SALDIRI VEKTÖRLERİ (11 FARKLI)

#	Vektör	Açıklama	Sonuç	Delil
1	SSRF	Export API'ye internal URL (73+ olay) gönderme, 18 port tarama	Portlar kapalı, SSRF callback teyit	D003, D010
2	AWS IMDS	169.254.169.254 metadata (9 endpoint) ECS credential erişimi	404 — Railway IMDS kapalı	D003
3	Redis RCE	gopher:// → Redis → Lua (3 payload) io.popen() shell komutu	Başarısız — Redis yok	paste.rs
4	Credit Manip.	Kayıttan 90 sn sonra +15.100 credit enjeksiyonu	Başarılı — kullanım sağlandı	D007
5	Path Traversal	../../../../etc/passwd.png dosya adıyla erişim	Tespit edildi, yama uygulandı	D003
6	Stored XSS	SVG içine <script> tag alert('XSS on ' + domain)	CDN'de depolandı (temizlendi)	CDN SVG
7	Phishing	SVG'ye sahte login formu → evil.example.com/steal	CDN'de depolandı (temizlendi)	CDN SVG
8	Kaynak Kod Okuma	Include file:///app/src/export/route.ts okuma	Başarısız	CDN SVG
9	Docker Daemon	Port 2375/2376/4243 socket erişim denemesi	ECONNREFUSED	Railway log
10	Admin Brute-force	25+ yetkisiz admin endpoint denemesi	401/403	D002, D004
11	Kalıcı Erişim	admin scope API key + 42+ sahte hesap	Key'ler iptal edildi	D008

5. KEŞFEDİLEN TİCARİ BİLGİLER

Keşfedilen Bilgi	Yöntem	Niteliği
AI desen üretim motorunun kapasitesi ve çıktı kalitesi	134 farklı desen üretimi	Ticari sır
Export pipeline (TIFF/PDF/PSD/Pack)	58+ export işlemi	Ticari sır
8K Upscale AI modelinin kapasitesi	6 adet 8K upscale	Ticari sır
İç ağ mimarisi (18 port haritası)	SSRF port tarama	Altyapı bilgisi
AI backend sağlayıcıları (Railway, CoreWeave IP'leri)	SSRF callback + SVG	Altyapı bilgisi
Credit/pricing modeli	Credit manipülasyonu	İş modeli

6. DELİL ENVANTERİ

Tüm delil dosyaları evidence/ klasöründe arşivlenmiştir. Her dosyanın SHA-256 hash değeri 08-hashes/SHA256SUMS.txt dosyasında kayıtlıdır.

Klasör	İçerik	Adet
01-server-logs	Railway sunucu logları, SecurityLog DB dökümü	9
02-database-dumps	User, Pattern, Credit, ApiKey, SecurityLog	15
03-webhook-evidence	2 webhook.site token + 32 callback kaydı	6
04-whois-dns	WHOIS, geolocation, DNS kayıtları	11
05-attacker-server	84.44.79.182 HTML snapshot, HTTP headers	5
06-cdn-artifacts	SSRF/XSS/Phishing SVG, RCE payload, upscale	14
07-osint	GitHub profili, AIT/MiraB2B web sayfaları	5
08-hashes	SHA256SUMS.txt	1
09-screenshots	Cloudflare Dashboard SS (kronolojik, indeksli)	20
Ek belgeler	Bilirkişi rehberi, teknik değerlendirme, savcılık talep listesi, doğrulama scripti, canlı saldırı raporu, rapor PDF	6

Toplam: 92 dosya, 4.0 MB, 9 klasör

7. EKTRAN GÖRÜNTÜLERİ (CLOUDFLARE DASHBOARD)

Aşağıdaki ekran görüntüleri, saldırı devam ederken platform sahibi Ali İlçel tarafından Cloudflare Security Analytics panelinden canlı olarak alınmıştır. Tüm SS'ler evidence/09-screenshots/ klasöründe SHA-256 hashli olarak arşivlenmiştir.

SS #	Saat	İçerik
SS-001	12:23	Cloudflare Security Analytics — saldırının ilk tespiti
SS-002	12:25	Saldırı detayları, istek tipleri
SS-003	12:29	Cloudflare Analytics — trafik anomalisi
SS-004	12:30	Saldırgan IP detayları
SS-005—009	12:45—12:51	Aktif SSRF/export denemeleri, curl/8.12.1 parmak izi, endpoint istekleri
SS-010	12:58	Cloudflare Security Analytics — kapsamlı görünüm
SS-011—012	13:41—13:42	Güvenlik önlemleri sonrası devam eden saldırı, WAF detayları
SS-013	13:47	.env, Kubernetes secrets, GitHub workflow secrets erişim denemeleri
SS-014	13:49	Credential harvesting — .git, config dosyaları
SS-015	13:50	Tor trafiği, ASN 60729, curl/8.12.1 user-agent
SS-016	13:53	Romanya IP (2.57.122.173) — .env dosyaları erişim denemesi
SS-017	13:53	Kronolojik saldırı listesi — tüm vektörler tek görüntüde
SS-018	13:56	ABD IP (DotBot/Moz SEO crawler) + saldırgan statik dosya okuma
SS-019	13:57	Cloudflare genel özet — ülke/browser/HTTP method dağılımı
SS-020	14:00	Cloudflare support ticket açılma ekranı

Bu SS'lerdeki veriler Cloudflare tarafında Security > Analytics > Sampled Logs bölümünden zaman filtresi uygulanarak bağımsız olarak doğrulanabilir.

8. KURULAN FORENSIC LOGLAMA SİSTEMİ

29 Nisan 2026 itibarıyla platforma forensic düzeyinde loglama sistemi kurulmuştur:

Kayıt Edilen	Kaynak	Depolama
Gerçek client IP	cf-connecting-ip header	SecurityLog DB + Railway
Ülke ve şehir	cf-ipcountry, cf-ipcity	SecurityLog DB
Cloudflare Ray ID	cf-ray header	SecurityLog DB
User-Agent	user-agent header	SecurityLog DB + Railway
Request body (payload)	POST body (4KB'a kadar)	SecurityLog DB
Kullanıcı kimliği	Session userId + email	SecurityLog DB
İstek path ve method	URL path + HTTP method	SecurityLog DB + Railway

Kayıtlar 3 bağımsız yerde tutulmaktadır: Cloudflare (CDN), PostgreSQL SecurityLog (uygulama) ve Railway console log (platform). Saldırgan bunların hiçbirini silemez.

9. ALINAN GÜVENLİK ÖNLEMLERİ

Önem	Durum
42+ saldırgan hesap banlandı, credit sıfırlandı	Tamamlandı
3 API anahtarı devre dışı bırakıldı	Tamamlandı
SSRF koruması: URL allowlist (sadece CDN + Replicate)	Deploy edildi
Internal IP/metadata/gopher/file engellendi	Deploy edildi
Callback servisleri engellendi (webhook.site, paste.rs, httpbin)	Deploy edildi
Path traversal koruması	Deploy edildi
API key scope kısıtlama (USER → admin scope yasak)	Deploy edildi
Disposable e-posta engellendi (deltajohnsons vb.)	Deploy edildi
Kendi domain'ile kayıt engellendi	Deploy edildi
Bilinen saldırgan IP'leri engellendi	Deploy edildi
Tor exit node'ları engellendi (T1)	Deploy edildi
Forensic loglama sistemi kuruldu	Deploy edildi
Deliller SHA-256 hashlenip arşivlendi	Tamamlandı
Wayback Machine arşivleri oluşturuldu	Tamamlandı
Cloudflare support ticket açıldı	Tamamlandı

10. RESMİ ADLİ İNCELEME TALEPLERİ

Talep	Kurum	Amaç
84.44.79.182 IP abone bilgileri (28-29 Nisan 2026)	BTK → Vodafone	IP → kişi tespiti
131.222.238.224 IP abone bilgileri (28 Nisan 2026 gece)	BTK → 4GNET	İkinci IP → kişi tespiti
2.57.122.173 IP abone bilgileri (29 Nisan 2026)	Romanya yetkilileri (uluslararası yardım)	Üçüncü IP → kişi tespiti
Webhook.site token kayıtları (2 token, son 7 gün)	Webhook.site (DK) (uluslararası yardım)	Token → IP teyidi
sapphiresc.com erişim logları	Cloudflare Inc. (ABD)	Saldırgan IP teyidi
A.I.T. sunucu incelemesi (84.44.79.182)	A.I.T. Bilg. Sis. (arama kararı ile)	Erişim kaynağı tespiti
A.I.T. mesai kayıtları (28-29 Nisan)	A.I.T. Bilg. Sis.	Ofiste bulunan kişi tespiti
HTS kayıtları (28 Nisan AIT→Sapphire)	BTK / Operatör	Hedef teyidi aramasının belgelenmesi

Webhook.site token #1 (e9da1ee6...) ve token #2 (aeae90e6...) 5 Mayıs 2026'da sona erecektir. Bu tarihten önce kayıtların resmi yollarla teyit edilmesi veya koruma altına alınması kritik önem taşımaktadır.

11. SONUÇ

Mevcut bulgular, sapphiresc.com platformuna yönelik 28-29 Nisan 2026 tarihlerinde gerçekleştirilen saldırının tek seferlik bir merak veya otomatik bot taraması olmadığını göstermektedir. Olay, iki gün boyunca, 6 farklı IP adresinden, 42+ sahte hesapla, giderek yoğunlaşan saldırı vektörleriyle (SSRF → XSS → RCE) sürdürülmüş hedefli ve sistematik bir saldırdır.

Saldırıyla ilişkilendirilen ana IP adresi (84.44.79.182) üzerinde A.I.T. Bilgisayar Sistemleri ile ilişkili web içeriğinin servis edildiği tespit edilmiştir. A.I.T., saldırıya uğrayan platformun doğrudan rakibi olan MiraB2B ürününü işletmektedir. Bu bağlantı, olayın ticari motivasyonlu olabileceğine dair kuvvetli şüphe oluşturmaktadır. Kesin şahıs tespiti, Bölüm 10'daki resmi adli inceleme taleplerinin sonuçlarına bağlıdır.

Saldırganın güvenlik önlemleri sonrasında başarısız kaldığı ve hiçbir API endpoint'ine erişemediği forensik kayıtlarla belgelenmiştir. Platform şu an korumalıdır.

12. SALDIRI SONRASI TESPİT EDİLEN DEĞİŞİKLİKLER

4 Mayıs 2026 tarihinde yapılan kontrollerde, saldırı sonrasında A.I.T. altyapısında aşağıdaki değişiklikler tespit edilmiştir:

Değişiklik	Önceki Durum (28 Nisan)	Sonraki Durum (4 Mayıs)
aitools.ait.com.tr DNS kaydı	84.44.79.182 (direkt IP, Vodafone Bursa)	172.67.211.131 / 104.21.77.206 (Cloudflare proxy — IP gizlenmiş)

Değişiklik	Önceki Durum (28 Nisan)	Sonraki Durum (4 Mayıs)
Port 5000 (AI Pattern Generator)	Aktif — Vue.js + Vite 'AI Pattern Generator' çalışıyor	BAĞLANTI REDDEDİLDİ (kapatılmış)
Port 5001 (Archivist admin panel)	Aktif — AIT logolu login sayfası	BAĞLANTI REDDEDİLDİ (kapatılmış)
Site erişimi	Açık — HTML içerik dönüyor	403 Forbidden (erişim engellenmiş)

A.I.T., saldırı tespit edilip kendilerine bildirilmesinin ardından saldırgan IP'yi Cloudflare proxy arkasına almış, üzerinde çalışan servisleri kapatmış ve siteyi erişime kapatmıştır. Bu davranış delil karartma girişi olarak değerlendirilebilir. Ancak 28 Nisan'daki snapshot'lar elimizde SHA-256 hashli olarak arşivlenmiştir.

12.1 Wayback Machine Karşılaştırması — Vectorizer / Upscaler

A.I.T.'nin aitools.ait.com.tr platformunda hiçbir zaman vectorizer, upscaler veya multi-format export (TIFF/PDF/PSD) özelliği bulunmamıştır. Tüm Wayback Machine arşivleri ve bizim snapshot'ımız bunu doğrulamaktadır:

Tarih	Kaynak	Vectorizer	Upscaler	Export
2023 Eylül	Wayback Machine	YOK	YOK	YOK
2024 Nisan	Wayback Machine	YOK	YOK	YOK
2024 Mayıs	Wayback Machine	YOK	YOK	YOK
2026-04-28	Bizim snapshot (D019)	YOK	YOK	YOK
2026-05-04	Canlı kontrol	403 (kapalı)	403 (kapalı)	403 (kapalı)

Sapphire B2B platformunda ise vectorizer, 8K upscaler ve TIFF/PDF/PSD export özellikleri mevcuttur ve saldırgan bunları aktif olarak kullanmıştır (58+ export, 6 upscale, 134 desen). Eğer A.I.T. bundan sonra bu özellikleri kendi platformuna eklerse, Sapphire'dan elde edilen ticari sır bilgilerine dayandığı kuvvetle muhtemeldir.

Rapor Sonu

Oluşturma: 04/05/2026 18:51 UTC+3

Ek: evidence/ klasörü — 94+ delil dosyası, SHA-256 hashli

Ek: 24 adet Cloudflare Dashboard ekran görüntüsü

Ek: Saldırı sonrası DNS değişikliği ve Wayback karşılaştırma belgeleri